

GuardDuty: protection plans and attack sequences

Why enabling GuardDuty is not the same as being covered – and what Extended Threat Detection changed.

GuardDuty reads logs **you never enabled**,
and it reads them through its own private
stream.

The three foundational data sources

- ◆ **CloudTrail management events.** Control plane. Not data events – those are S3 Protection.
- ◆ **VPC Flow Logs** from EC2 network interfaces in the account.
- ◆ **Route 53 Resolver DNS query logs**, through the internal AWS resolvers.
- ◆ All three come free with GuardDuty, need no configuration, and cost nothing extra to consume.
- ◆ GuardDuty **extracts fields and discards the logs**. You cannot go and read them afterwards.

ON THE EXAM

Foundational means automatic. If an answer says 'enable VPC Flow Logs so GuardDuty can analyse them', it is wrong.

Three consequences most courses skip

- ◆ **A third-party DNS resolver blinds GuardDuty to DNS.** OpenDNS, Google DNS or your own resolver.
- ◆ **Global service events** – IAM, STS, S3, CloudFront, Route 53 – replicate into **every** enabled Region.
- ◆ So AWS advises enabling it in **all Regions, including empty ones**.
- ◆ For those events, a finding's Region may differ from where detection happened.
- ◆ No DNS monitoring for EC2 on **AWS Outposts**.

ON THE EXAM

The DNS resolver dependency is silent. No console warns you about it.

Everything else is a protection plan you switch on

PROTECTION PLAN	WHAT IT ADDS
S3 Protection	CloudTrail S3 data events – exfiltration, not just policy changes
EKS Protection	EKS audit logs – the Kubernetes control plane
Runtime Monitoring	OS-level events on EC2, ECS including Fargate, and EKS
Malware Protection for EC2	Agentless scan of EBS volumes when behaviour looks bad
Malware Protection for S3	Scans objects on upload
Malware Protection for AWS Backup	Scans backup data
RDS Protection	Aurora login events
Lambda Protection	Network activity logs from Lambda functions
AI Protection	Bedrock and SageMaker AI CloudTrail data events

ON THE EXAM

Nine plans. 'GuardDuty is enabled' tells you almost nothing about coverage without knowing which of these are on.

Extended Threat Detection

- ◆ **On by default, no extra cost**, in every account and Region where GuardDuty runs. You do not enable it.
- ◆ It correlates **signals** – API activity plus existing findings, including **weak signals** that mean nothing alone.
- ◆ Detects in-progress or recent behaviour within a **24-hour rolling window**.
- ◆ Output is one **attack sequence** finding, and every attack sequence finding is **Critical**.
- ◆ It carries an incident summary, an event timeline, and MITRE ATT&CK tactics and techniques.

ON THE EXAM

The unit of alerting changed. Instead of twelve medium findings for an analyst to assemble, one critical finding with the story already told.

Attack sequences, and what each one needs turned on

FINDING	REQUIRES
<code>AttackSequence:IAM/CompromisedCredentials</code>	Nothing. Foundational sources are enough
<code>AttackSequence:S3/...</code>	S3 Protection, for the exfiltration half
<code>AttackSequence:EKS/CompromisedCluster</code>	EKS Protection or Runtime Monitoring. Both is better
<code>AttackSequence:ECS/CompromisedCluster</code>	Runtime Monitoring. Fargate or EC2
<code>AttackSequence:EC2/CompromisedInstanceGroup</code>	Foundational works. Runtime Monitoring deepens it

ON THE EXAM

ETD is free. The signals are not. Coverage tracks which plans you bought.

The suppression rule trap

- ◆ **Extended Threat Detection ignores archived findings**, including ones auto-archived by a suppression rule.
- ◆ So a broad suppression rule silently removes signals from attack sequence correlation.
- ◆ The finding you archived as noise is often the first step of the sequence you want.
- ◆ AWS says explicitly: review existing suppression rules now ETD exists.
- ◆ Prefer **filters** for triage. A filter changes your view; suppression changes what GuardDuty reasons about.

ON THE EXAM

A 2023 tuning decision can disable a 2024 capability. Nothing tells you.

EKS Protection or Runtime Monitoring?

EKS PROTECTION SEES

The control plane

- Kubernetes audit logs
- RBAC changes and secret access
- Anomalous privileged pod deployment
- No agent to deploy anywhere

RUNTIME MONITORING SEES

Inside the container

- Processes, files, network syscalls
- Cryptomining and reverse shells
- Also covers ECS, Fargate and EC2
- Needs the GuardDuty security agent

THE TIEBREAKER

'Who asked Kubernetes for something' is EKS Protection. 'What is running in there' is Runtime Monitoring.

GuardDuty across an organisation

- ◆ Designate a **delegated administrator** from the management account. Run GuardDuty from the security account, not the management account.
- ◆ Set **auto-enable** so new accounts joining the organisation are covered with no action. Per protection plan, too.
- ◆ The administrator sees all member findings, and can enable or disable protection plans centrally.
- ◆ **GuardDuty is Regional.** Delegated admin and auto-enable are configured per Region.
- ◆ Findings go to **EventBridge automatically**, and optionally export to an S3 bucket you nominate.

ON THE EXAM

Delegated administrator plus auto-enable is the answer to almost every 'new accounts are not covered' question.

What GuardDuty will not do

- ◆ **It does not block anything.** It detects. Response is EventBridge into Lambda, Step Functions or Security Hub.
- ◆ **It does not find vulnerabilities.** An unpatched CVE is Inspector. GuardDuty sees someone exploiting it.
- ◆ **It does not read your data.** Sensitive content is Macie. Malware Protection scans for malware, not for card numbers.
- ◆ **It does not check configuration.** A public bucket is Config or Security Hub CSPM.
- ◆ It is a **detective** control that consumes behaviour. Everything above is a different control type.

ON THE EXAM

Inspector finds the unlocked door. GuardDuty sees someone walk through it. That sentence resolves a lot of questions.

A logistics company enables GuardDuty in every Region across its organisation, with a delegated administrator and auto-enable switched on. Findings flow into Security Hub and the team reviews them weekly.

An incident response retainer firm runs a red team exercise. Their implant beacons to a command-and-control domain from EC2 instances every few minutes for two weeks. GuardDuty raises no DNS-related findings at all, although it does raise findings about unusual API calls made with the instance role. The company operates its own DNS resolvers inside each VPC to support hybrid name resolution.

Why did GuardDuty raise no DNS findings?

- | | |
|--|---|
| ☐ A GuardDuty can only process DNS query logs from the internal AWS resolvers | ☐ B Route 53 Resolver query logging was never enabled on the VPCs |
| ☐ C VPC Flow Logs must be enabled before GuardDuty can correlate DNS activity | ☐ D DNS monitoring requires the Lambda Protection plan to be enabled |

◆ PAUSE AND DECIDE

Why did GuardDuty raise no DNS findings?

- A

 GuardDuty can only process DNS logs from the internal AWS resolvers
Correct. Custom resolvers inside the VPC mean the queries never traverse the AWS resolvers, so GuardDuty has no DNS data. No console warns you.
- B

 Route 53 Resolver query logging was never enabled
The classic trap. GuardDuty uses an independent stream and never requires you to enable a foundational source. Enabling query logging would change nothing.
- C

 Flow Logs must be enabled first
Same misconception in a different costume. Flow Logs are also foundational and also consumed independently. And the API findings prove GuardDuty is working.
- D

 DNS monitoring requires Lambda Protection
Lambda Protection adds network activity logs for Lambda functions. It has nothing to do with EC2 DNS resolution.

THE SIGNAL

The last sentence is the answer, and it reads like background. 'We run our own DNS resolvers' is a detection gap statement.

A bank has run GuardDuty for four years. In 2023, to control alert fatigue, the team created suppression rules that automatically archive several finding types they judged to be noise, including Recon:EC2/Portscan and several UnauthorizedAccess:IAMUser findings from a known-noisy CI subnet.

In a recent post-incident review, an attacker was found to have enumerated IAM permissions, escalated privileges and exfiltrated S3 data over about eight hours. GuardDuty raised several individual findings but never produced an attack sequence finding. S3 Protection and Runtime Monitoring are both enabled.

Why was no attack sequence finding generated?

- ☐ A Extended Threat Detection must be enabled separately in each member account
- ☐ B Attack sequences require all nine protection plans to be enabled
- ☐ C The attack lasted eight hours, exceeding the correlation window
- ☐ D The suppression rules archived component findings, and archived findings are excluded from correlation

Why was no attack sequence finding generated?

- A

 ETD must be enabled per member account
It is on by default wherever GuardDuty runs, at no cost, with nothing to enable. This is a distractor built on the shape of other AWS features.
- B

 All nine protection plans are required
More plans widen coverage, but none is mandatory. The two that matter for this attack, S3 Protection and Runtime Monitoring, were already on.
- C

 Eight hours exceeded the correlation window
The window is a 24-hour rolling one, so eight hours sits comfortably inside it. Right kind of reasoning, wrong number.
- D

 Suppression rules archived the component findings
Correct. ETD ignores archived findings, including auto-archived ones. The 2023 tuning decision silently disabled a 2024 capability.

THE SIGNAL

A control that was correct when written became a blind spot when the service changed underneath it. Review suppression rules.

A media company runs its entire platform as ECS services on AWS Fargate. There are no EC2 instances anywhere in the account. GuardDuty is enabled with S3 Protection, EKS Protection, Malware Protection for EC2 and RDS Protection.

The security team wants GuardDuty to detect a container that has been compromised through a vulnerable web application and is running a cryptominer, and wants it correlated into a single critical finding rather than arriving as separate alerts.

What must the security team enable?

- | | |
|---|--|
| ☐ A EKS Protection, which already covers container workloads | ☐ B Malware Protection for EC2, to scan the container's storage |
| ☐ C Lambda Protection, for the network activity logs | ☐ D Runtime Monitoring, which covers ECS on Fargate |

◆ PAUSE AND DECIDE

What must the security team enable?

A EKS Protection

Already enabled, and irrelevant. EKS Protection reads Kubernetes audit logs. This platform runs ECS, which has no Kubernetes control plane at all.

C Lambda Protection

Network activity logs for Lambda functions. No Lambda in this architecture, and it would not see inside a container regardless.

B Malware Protection for EC2

Also already enabled, and it scans EBS volumes attached to EC2 instances. The scenario says there are no EC2 instances anywhere.

D Runtime Monitoring

Correct. It is the only plan that observes processes inside ECS containers on Fargate, and ECS attack sequences require it.

THE SIGNAL

Three of the four options were already enabled. A long list of enabled plans is misdirection, not reassurance.

An insurer has 250 accounts in AWS Organizations and creates roughly four new accounts each week for project teams. GuardDuty was enabled account by account over two years using a CloudFormation StackSet that a platform engineer maintains and re-runs manually.

An audit finds 31 accounts with GuardDuty disabled or missing protection plans, and no central view of findings. The security team wants coverage guaranteed for every current and future account, operated from the security account rather than the management account.

What should the insurer implement?

- ☐ A Designate the security account as GuardDuty delegated administrator and turn on auto-enable for the organisation, per Region
- ☐ B Extend the CloudFormation StackSet to use automatic deployment to the organisation root
- ☐ C Create an AWS Config rule with an SSM Automation remediation that enables GuardDuty when it is found disabled
- ☐ D Invite all 250 accounts as GuardDuty members from the management account

◆ PAUSE AND DECIDE

What should the insurer implement?

- A

 Delegated administrator plus auto-enable for the organisation
Correct. Native, no code to maintain, covers future accounts automatically, gives one central findings view, and runs from the security account as required.
- B

 StackSet with automatic deployment to the org root
The best distractor. It would cover new accounts, but it is still IaC to maintain, it gives no central findings view, and a member can disable GuardDuty afterwards.
- C

 Config rule with SSM Automation remediation
Detective then corrective, so there is always a window where an account is uncovered. It is a way to catch drift, not a way to prevent it.
- D

 Invite all 250 accounts as members
Invitation is the mechanism for accounts outside your organisation. It also requires each account to accept, which is exactly the manual work being escaped.

THE SIGNAL

'Operated from the security account' is the phrase that names delegated administrator. It appears in this exam constantly.

Five things to carry forward

- ◆ **Foundational sources need no configuration.** 'Enable Flow Logs so GuardDuty can see them' is always wrong.
- ◆ **A third-party DNS resolver blinds GuardDuty to DNS.** Silent, and nothing warns you.
- ◆ **Extended Threat Detection is free and automatic. The signals are not.** Coverage tracks your protection plans.
- ◆ **Suppression rules remove findings from attack sequence correlation.** Filters change your view; suppression changes GuardDuty's reasoning.
- ◆ **Delegated administrator plus auto-enable** answers every 'new accounts are not covered' question.

ON THE EXAM

Next: six questions, six services – Config, Security Hub CSPM, Inspector and Macie.